HOSPITALITY CYBERSECURITY

THE BOOKING DESK

IS A SECURITY BOUNDARY

A Practical Cybersecurity and Guest-Data Guide for
Small Hotels, Guesthouses and Holiday Rentals

BOOKING PLATFORMS · PMS · GUEST DATA · GDPR

ZIRLANDIA MILKOVIC

HOSPITALITY CYBERSECURITY

THE BOOKING DESK IS A SECURITY BOUNDARY

A Practical Cybersecurity and Guest-Data Guide for Small Hotels, Guesthouses and Holiday Rentals

ZIRLANDIA MILKOVIC

The Booking Desk Is a Security Boundary
A Practical Cybersecurity and Guest-Data Guide for Small Hotels, Guesthouses and Holiday Rentals

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 13 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional. Laws, court cases and vendor settings reflect the research cut-off date and should be checked against the current legal texts, regulator guidance and vendor documentation.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Message That Knew the Room Number 4
Who This Book Is For 6
How to Use This Book 6
The Ten-Minute Booking-Desk Check 7

CHAPTERS

1. Why the Booking Desk Is a Security Boundary 9
2. Protecting Booking-Platform Accounts 15
3. PMS and Channel-Manager Security 20
4. Guest-Data Access and Staff Permissions 25
5. Fraudulent Reservation Messages 30
6. Secure Guest-Communication Procedures 34
7. GDPR Breach Escalation 39
8. The Front-Desk Security Checklist 46

CLOSING

Conclusion: Guard the Desk, Keep the Welcome 50

APPENDICES

Appendix A: Booking-Desk System Inventory 52
Appendix B: Role-and-Permission Matrix and Staff Access Register 54
Appendix C: Suspicious-Message Triage Card 56
Appendix D: Guest-Communication Scripts and Templates 57
Appendix E: Incident Contacts, 72-Hour Steps and Incident Log 59
Appendix F: The Front-Desk Security Checklist (Print and Pin) 61
Appendix G: Retention Register and 30-Day Tracker 62

BACK MATTER

Glossary 64
A Note on GDPRGard.eu 64
About the Author 66
Notes and Sources 67

Educational Disclaimer

This book is practical, educational guidance for owners and managers of small hotels, guesthouses, bed-and-breakfasts, holiday rentals and other accommodation businesses, and for the front-desk and reservations staff who work in them. It is not legal, security, data-protection or regulatory advice, and it does not create a professional relationship between the author and the reader.

Cyber-crime changes quickly, and so do the booking platforms, property-management systems and channel managers it targets. The settings, menus and features of any product described in general terms here will differ by vendor, by plan and by month. Regulatory proceedings described in this book are investigations, not findings. The author has relied on secondary summaries for some points, and the notes at the back say which, and list what could not be verified. Before you change a system, notify a regulator, accuse a guest or contact a platform about a suspected breach, check the vendor's current documentation, your national data-protection authority's guidance and, where the stakes are high, take professional advice.

Following the steps in this book can make your property harder to attack and easier to defend. It cannot guarantee that you will never be targeted, and it cannot guarantee how a regulator, an insurer, a platform or a court will treat any particular incident.

Every business, person and incident in a worked example is **fictional** and labelled as such. Platform and product names appear only to describe how a category of tool works; no company is accused of anything by this book.

Introduction: The Message That Knew the Room Number

Marta and Pavle run the Villa Lavanda, a twelve-room guesthouse on a southern European coast. On a Friday in September, at ten past nine in the evening, a guest called Mr Albrecht, arriving the next afternoon for a week, received a WhatsApp message. It used his name. It gave his reservation number, his dates, the name of the room type he had booked and the exact total. It said the property's card payment system had failed, that his booking

would be cancelled within two hours unless he confirmed his card details through the secure link below, and it was signed with the guesthouse's name.

Mr Albrecht paid. Two hours later he rang the real Villa Lavanda in a panic, because the card he used was already being spent in a city he had never visited. Pavle, who had sent nothing, spent the night learning three things. The message had come from nobody at the guesthouse. The only people who could have known the reservation number and the room type were the booking platform, Marta's own accounts, and whoever had got inside one of them. And he had no idea which.

That is the shape of the problem this book exists to solve. A small property does not run one system. It runs a chain: a booking platform that brings guests in, a channel manager that spreads the calendar across several of them, a property-management system that holds the guest list, a payment terminal, an email account, a phone with a messaging app, and a front desk where a tired person decides, forty times a day, whether to believe what is on a screen. Each link holds guest names, dates, phone numbers, sometimes passport details and payment tokens. Each link is a door. And the most valuable thing a criminal can learn is not a password. It is a **real reservation**, because a real reservation turns an anonymous scam into one a guest believes.

This is no longer a theoretical worry. In October 2026 the European Commission opened formal proceedings under the Digital Services Act to investigate whether one of the largest booking platforms adequately assesses and reduces the risk of fraudulent listings and phishing, including scams that exploit reservation and guest data.[1] A few weeks later, hospitality associations in Germany were warning members about booking-related scams that use genuine reservation details, and about the possibility that hotel accounts, property-management systems and channel managers had been compromised to obtain them.[2] Those are investigations and warnings, not verdicts. But they say clearly where the industry's attention has moved: from the guest who is tricked to the property whose data made the trick convincing.

Notice what that means for a small operator. You are not only a possible victim of fraud against your own business. You are a **custodian of other people's data**, and when it leaks through your systems it is your name on the message, your guest on the phone and, under the GDPR, your duty to report it.

This book is written for you, not for the vendor's IT team and not for a global hotel chain. It will not ask you to buy a security product. It will ask you to look, once, at the accounts and habits you already have, and to treat

the booking desk, wherever it is, as what it has become: a **security boundary**. Behind it sit your guests. In front of it sit people who would like to impersonate you.

Who This Book Is For

This book is written for the people who end up owning the question "is this safe?" in accommodation businesses too small to employ an IT department:

- **Owners of independent hotels and guesthouses** who run the property, the accounts and often the front desk themselves.
- **Holiday-rental hosts** with one to thirty units, listed on several platforms and managed from a phone.
- **Accommodation managers and duty managers** who inherit logins, shared mailboxes and software chosen years ago by someone who has since left.
- **Front-desk and reservations staff**, part-time, seasonal or agency, who are the first to see a suspicious message and the last line of defence against it.
- **Small groups and management companies** that look after several properties on behalf of owners and need one simple standard to apply to all of them.

It is written from a European, GDPR-first point of view, because that is where the strictest duties on guest data sit, and it is deliberately vendor-neutral: it describes categories of system and the questions to ask of them, not particular menus. It is not written for the platforms or for software vendors, and it is not a legal treatise. It tells you what to do on Monday morning and what to ask your lawyer afterwards.

How to Use This Book

The eight chapters follow the path of a reservation, from the moment it arrives to the moment something goes wrong:

1. **Why the booking desk is a security boundary.** The chain of systems, what each holds, and how a criminal moves along it.
2. **Protecting booking-platform accounts.** Logins, multi-factor authentication, shared access, recovery routes and the phishing emails aimed at hosts.
3. **PMS and channel-manager security.** The two systems that hold the most data and get the least attention.

4. **Guest-data access and staff permissions.** Who sees what, for how long, and what happens when someone leaves.
5. **Fraudulent reservation messages.** How the scams work, the signs of each, and how to check a message in under a minute.
6. **Secure guest-communication procedures.** What you will and will not ask for, and through which channel, so that guests can tell you from an impostor.
7. **GDPR breach escalation.** The first hour, the first day, the 72-hour clock and who must be told.
8. **The front-desk security checklist.** Daily, weekly and monthly habits, and a thirty-day plan to put them in place.

The appendices are working documents: a system inventory, a role-and-permission matrix, a suspicious-message triage card, guest-communication scripts, a breach-escalation log, the front-desk checklist and a thirty-day tracker. Copy them, fill them in, pin them up and keep them current.

Look for the dark boxes headed **The rule**. Each states, in one sentence, the principle a chapter turns on. If you read nothing else, read those.

The Ten-Minute Booking-Desk Check

Before the first chapter, answer these honestly. A "no" or "I don't know" is not a failure. It is the start of your to-do list.

- ☐ I can list every platform, channel manager, PMS, payment tool and shared mailbox that holds guest data in my business.
- ☐ Every booking-platform and PMS login uses multi-factor authentication, not just a password.
- ☐ Every person who logs in has their own account; nobody shares one login.
- ☐ I know who could reset the password on each system, and to which email address or phone the reset goes.
- ☐ Staff can see only the guest data their job needs, and leavers lose access on their last day.
- ☐ Staff know, in one sentence, how to check a payment or "urgent" request that claims to come from a platform or a guest.
- ☐ We have a written rule on what we will never ask guests to send by message (card numbers, ID scans, passwords).
- ☐ I know who decides whether an incident is a personal-data breach, and how to reach them at 9 p.m. on a Saturday.
- ☐ We keep a log of incidents, including near misses.

☐ Our front desk has a printed checklist, and someone reviews it.

Score one point for each box you can tick without hesitation. Under five means every chapter will be immediately useful; start with the appendices. Between five and eight means you have the basics and will find the gaps in Chapters 3, 4 and 7. Nine or ten means you may be ahead of most properties; check your answers against the evidence, not your memory.

CHAPTER 1

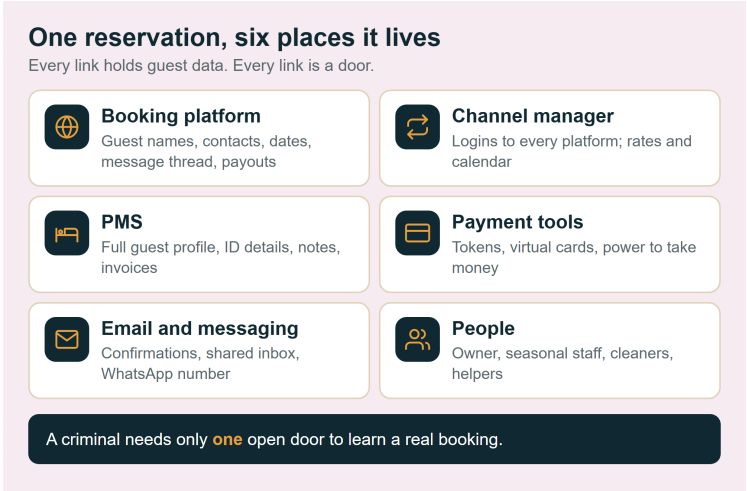
Why the Booking Desk Is a Security Boundary

A reception desk is the visible edge of a much larger set of systems

When people picture hotel security they picture locks, cameras and key cards. Those matter. But for a small property the more valuable assets are not behind a door. They are behind a login. A guest list for the next ninety days, with names, phone numbers, email addresses, arrival times and the sums each guest has paid, is worth more to a fraudster than the till, and it can be stolen from a kitchen table in another country.

The chain behind every reservation

A reservation does not live in one place. It travels.



The chain of systems a single reservation passes through, and what each holds

The booking platform. The marketplace where the guest finds you. It holds the guest's name, contact details, dates, the message thread between you, and often a virtual or real card. Your extranet or host account is the control panel for all of it.

The channel manager. Software that keeps your prices and availability the same across several platforms, so that a room sold on one is closed on the others. It holds the logins and connections to every platform you use. That makes it unusually powerful: whoever controls it controls your calendar everywhere.

The property-management system (PMS). The hotel's back-office record: guest profiles, arrival lists, room assignments, invoices, sometimes passport or ID details collected for local registration rules, and notes such as dietary or medical needs. In a very small property it may be a spreadsheet. The risks are the same.

Payment tools. A card terminal, a payment link, a virtual card shown in the extranet, an online payment page. These hold tokens or fragments of card data and, more importantly, the power to take money.

Email, phone and messaging. The shared mailbox that receives confirmations, the WhatsApp number printed on the website, the phone that rings at the desk. These are where guests meet you, and where impostors meet them.

People. The owner, the seasonal receptionist, the cleaner with a tablet, the accountant, the nephew who built the website. Every one is a path in, and every one is also a defender.

Why criminals like small properties

Large chains have security teams. A twelve-room guesthouse has a phone and good intentions. Four things make independent properties attractive.

- **Shared and long-lived logins.** One extranet password, known to three people and unchanged for four years.
- **Seasonal and part-time staff.** High turnover means constant new access and frequent forgotten removals.
- **Time pressure.** An arrival at midnight, a full house at breakfast, a message that says "urgent". Fraud works best on busy people.
- **No one whose job is security.** It falls to whoever is nearest, and so to no one.

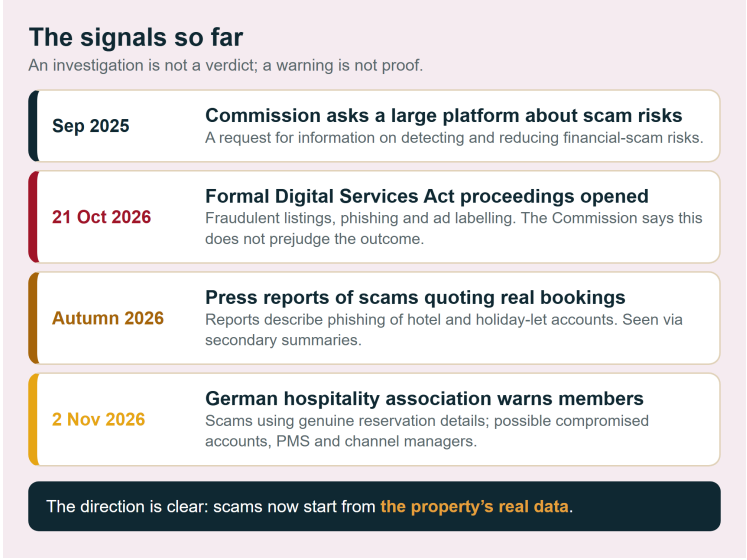
What a criminal actually wants

The aims are modest and profitable. In rough order of how often they appear:

1. **Money from your guests.** A convincing message that asks them to "confirm" or "re-enter" card details, or to pay a "deposit" to a new account.
2. **Money from you.** Fake payment demands, fake invoices, diverted payouts from a platform, or a payment-link swap.
3. **Reservation data to sell or reuse.** Lists of real bookings are traded because they make later scams more believable.
4. **Access itself.** A compromised host or channel-manager account can be used to post fake listings, cancel real bookings, redirect payouts or message every guest at once.

The signals worth noticing

Three developments make this urgent rather than theoretical.

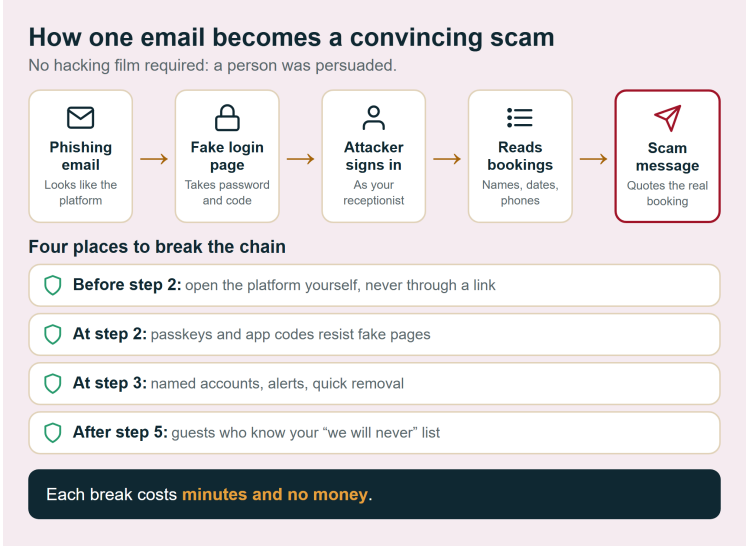


Recent signals that guest and reservation data have become a target

In October 2026 the European Commission opened formal proceedings under the Digital Services Act to investigate whether a very large booking platform properly assesses and mitigates risks from fraudulent listings and phishing. It said opening proceedings does not prejudge the outcome.[1] In early November a German hospitality association warned its members about booking-related scams that use genuine reservation details, and raised the possibility that hotel accounts, property-management systems and channel managers might have been compromised.[2] Reporting on the same wave of scams describes attackers phishing hotel accounts to reach the booking-management tools, and hotel and holiday-let operators having their credentials taken first.[3]

Read each against its source. A regulator investigating a platform has not found the platform guilty. An association's warning is not proof that any named system was breached. What they do establish is the direction of travel: **criminals have learned that the cheapest way to make a scam believable is to start from the property's real data.**

How an attack moves along the chain



A typical path from a phishing email to a scam message that uses a real reservation

Here is a composite, fictional example. A receptionist at a small seaside hotel receives an email that appears to come from a booking platform: "Your account has a guest complaint. Log in to respond within 24 hours." The link leads to a page that looks identical to the platform's login. She types her email and password, and, because the fake page also asks for the code sent to her phone, she types that too. Within minutes the attacker is logged in as her. From the extranet they can read every upcoming reservation, with names, dates and phone numbers. They do not touch the property's systems at all. They simply start sending guests a message, from outside the platform, that quotes the reservation exactly.

Nothing was hacked in the cinematic sense. A person was persuaded. That is why the defences in this book are mostly **habits and settings**, not technology.

> **The rule:** Treat every place a reservation lives as part of your front door, and give the door the same care you give the lock.

What this book will ask of you

Five things, repeated in different forms throughout:

1. **Know the chain.** Write down every system and who can reach it.

2. **Close the easy doors.** Multi-factor authentication, individual accounts, safe recovery routes.
3. **Limit what each person can see.** Least access, removed promptly.
4. **Make impersonation hard.** Say, in advance, how you will and will not contact guests.
5. **Be ready to report.** Know the breach steps before you need them.

Start the next chapter with a pen and Appendix A open beside you.

CHAPTER 2

Protecting Booking-Platform Accounts

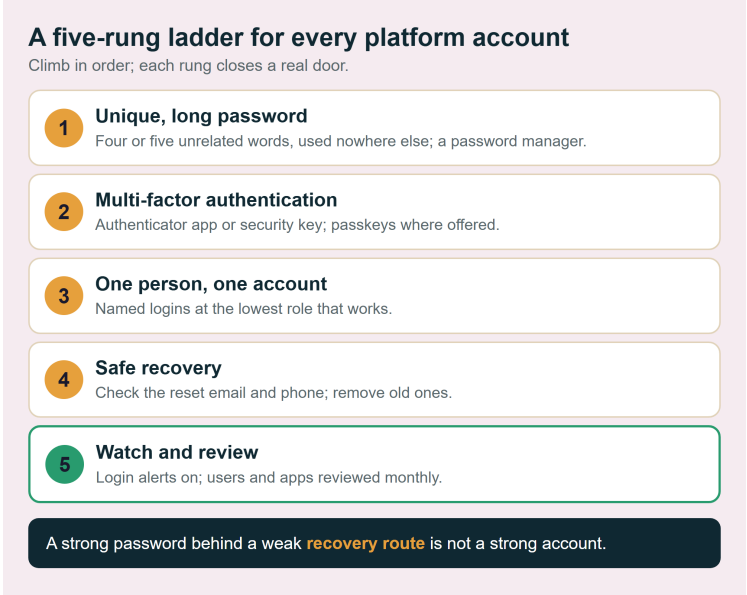
CHAPTER 2
PROTECTING BOOKING-PLATFORM ACCOUNTS

A row of keys is a good picture of how many people can reach one account

The booking-platform account is the single most valuable login in most small properties. Through it a person can read guest data, message guests, change prices, cancel bookings, and in many cases alter where payouts go. It deserves more care than your email, and almost no one gives it any.

The ladder of account protection

You do not need to do everything at once. Climb in order.



A five-step ladder from a bare password to a hardened account

Rung 1: a unique, long password. Not a name, not the property, not a year. A password manager makes this painless. Where a manager is not possible, use a long passphrase of four or five unrelated words that is used nowhere else.

Rung 2: multi-factor authentication (MFA). Turn it on for every platform and for every system that offers it. Prefer an authenticator app or a hardware security key to codes sent by text message, because text messages can be redirected and because phishing pages can ask for them. Where a platform offers passkeys, they resist phishing better than a password plus a code, because they will not work on a fake site.

Rung 3: one person, one account. If three people use "reception@" and one shared password, you cannot tell who did what, you cannot remove one person without changing everyone's access, and you cannot enforce MFA on a phone that three people share. Give each person their own sign-in, with the lowest permission that lets them do their job.

Rung 4: safe recovery. Every account has a back door called "forgot password". The attacker's route is often not the front door at all. Check, for every platform:

- which **email address** receives the reset link, and who can read that mailbox;
- which **phone number** receives codes, and whose phone it is;
- whether any **old address** or a former employee's number is still attached.

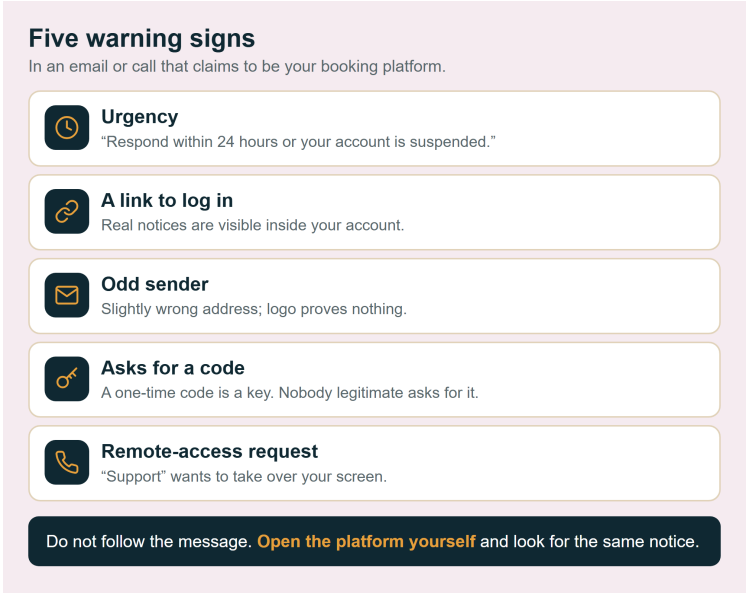
A strong password protecting an account whose reset goes to a personal mailbox that nobody checks is not a strong account.

Rung 5: watch and review. Turn on login alerts where offered. Once a month, look at the list of users, the connected apps and the recent logins. Remove anything you cannot explain.

> **The rule:** An account is only as strong as the weakest way to recover it.

The phishing emails aimed at hosts

The most common way in is not a technical attack. It is a message built to look like it came from the platform.



Five warning signs in an email that claims to come from a booking platform

Typical stories are: a guest has complained and you must respond today; your account will be suspended unless you verify your details; a payout has failed; a guest's payment cannot be processed and you must re-enter it; a "security update" needs your login. Each creates urgency and offers a link.

Five habits defeat almost all of them.

- **Do not log in from a link in a message.** Open the platform yourself, using a bookmark or by typing the address, and look for the same notice inside your account. If it is real, it will be there.

- **Look at the sender and the link, not the logo.** A logo proves nothing. Hover over the link on a computer, or press and hold on a phone, to see where it really goes. Slight misspellings, extra words or unusual endings are warnings.
- **Be most suspicious of urgency.** A real platform may send reminders. It rarely requires a login in the next two hours.
- **Never type a code anyone asks you to read out.** A one-time code is a key. Nobody legitimate will ask you to read it back to them over the phone or in a chat.
- **Report, do not just delete.** Forward suspicious messages to the platform's own security or abuse address (find it on its help pages, not in the message) and tell the rest of the team.

Phone calls and the "support" scam

Criminals also ring. A caller claims to be from the platform's security team, says your account has been accessed, and walks you through "protecting" it by installing a remote-access program or reading out a code. Platforms do not usually need to remote-control your computer. If a caller makes you feel hurried or frightened, hang up and call back on the number printed on the platform's own help page.

Hardening checklist for each booking platform

- ☐ Multi-factor authentication is on for every user, using an app or key where possible.
- ☐ No shared logins; each person has their own account and the lowest role that works.
- ☐ The reset email and phone belong to the business and are controlled by a named person.
- ☐ Login alerts and "new device" notices go to a mailbox someone reads.
- ☐ The list of users has been reviewed this month and leavers removed.
- ☐ Connected apps, channel managers and API connections have been listed and are all still needed.
- ☐ Payout details (bank account) are visible only to the owner or finance lead.
- ☐ Staff know how to report a suspected phishing email, and to whom.

If you think an account has been taken over

Do these in order, quickly:

1. From a **different, clean device**, change the password and sign out all sessions.
2. Check and, if needed, reset the **recovery email and phone** and the MFA method.
3. Review recent **messages sent**, **changes to payouts** and **new users or connected apps**; undo what you can.
4. **Tell the platform** through its official security route and ask what it can see.
5. Treat it as a possible personal-data breach and start the log in Chapter 7.

Fast action in the first hour matters more than a perfect explanation. Write down what you saw and when, even roughly. You will need it twice: for the platform, and for your own breach decision.

CHAPTER 3

PMS and Channel-Manager Security

CHAPTER 3
PMS AND CHANNEL-MANAGER SECURITY

The back-office laptop holds more guest data than any front-of-house screen

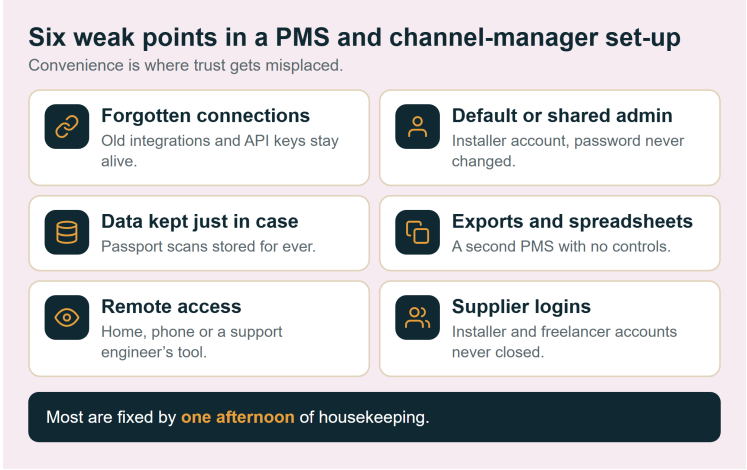
If the booking platform is the front door, the PMS and the channel manager are the building's central corridor. Most owners chose them for convenience, set them up once and have not looked at them since. They hold the most data and rarely get a security review.

What each system really holds

A **channel manager** sits between you and your platforms. It stores the sign-in connections to each platform, your rates and availability, and often copies of reservations and guest messages. A weak password here does not expose one site; it exposes every site you sell on, and lets an intruder close your calendar, change prices or cancel bookings in a moment.

A **PMS** holds the full guest record. Depending on how you use it, that can include names, addresses, phone numbers, email, nationality, dates of birth, passport or ID details collected for registration, vehicle plates, stay history, spending, preferences and free-text notes. Some of those notes are sensitive: an accessibility need, an allergy, a request for a quiet room after a bereavement. Under the GDPR, information that reveals health is a special category and deserves extra care.[4]

Where the weak points are



Six points in a PMS and channel-manager set-up where trust is easily misplaced

Connections you forgot. Channel managers connect to platforms, to the PMS, to payment providers and often to a website booking engine. Each connection is a credential or token. When you stop using a tool, its connection often stays alive.

Default and shared admin accounts. Software is commonly installed with an administrator account created by the supplier or an installer, and the password is never changed. Shared admin accounts mean nobody is accountable.

Excess data collected "just in case". If your PMS stores passport scans for every guest forever, a single breach exposes them all. Data you do not hold cannot be stolen.

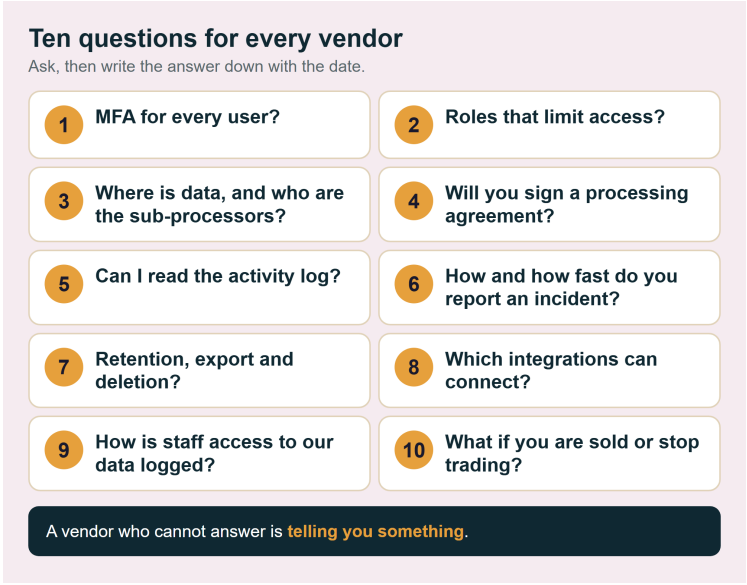
Exports and spreadsheets. An arrival list exported to a spreadsheet, emailed to the cleaning company and saved on a personal laptop is now a second PMS with no controls at all.

Remote access. Many small PMS products are reached from home, from a phone or by a support engineer using a remote-access tool. That convenience is also an entry point.

Supplier access. The vendor's support staff, the installer who set it up and the freelancer who integrated your website may each have a login. Many of those logins are never closed.

Ten questions to ask your PMS and channel-manager vendors

You do not need technical knowledge to ask these. You need only to ask, and write down the answer.



The questions that separate a safe vendor from a hopeful one

1. **Does every user sign in with multi-factor authentication, and can you require it for all of them?**
2. **Can I give each person a role that limits what they see and do?**
3. **Where is our data stored, and which companies process it on your behalf?** In the GDPR's terms, who are your sub-processors?
4. **Will you sign a data-processing agreement?** If you use the system to process guest data, the GDPR requires a written contract with the processor.[5]
5. **Is there a log of who viewed, changed or exported guest data, and can I read it?**
6. **How do you tell customers about a security incident, and how quickly?** You will have 72 hours from becoming aware of a breach to decide on notifying your regulator, and that clock may start when you learn of it, not when the vendor tells you.[6]
7. **How long do you keep our data after we leave, and how do I export or delete it?**
8. **Which third-party tools and integrations can connect, and who approves them?**
9. **How do your own staff access our data, and is it logged?**

0. **What happens to our data and logins if you are sold or stop trading?**

Keep the replies with the date and the name of the person who gave them. A vendor who cannot answer these is telling you something.

> **The rule:** If a system holds guest data, you must be able to say who can reach it, how, and what you would do the day it was misused.

Securing the things you control

Even with a modest vendor, a lot is in your hands.

- **Change every default.** Rename or disable default admin accounts and set new strong passwords.
- **Switch on MFA** for every user, and enforce it if the product allows.
- **Create named accounts and roles** (Chapter 4) rather than sharing a login.
- **Set the retention period.** Decide how long guest records stay, and where the product allows, set automatic deletion or anonymisation.
- **Stop collecting what you do not need.** If you scan passport pages only to meet a legal registration rule, find out the rule and keep only what it needs, for as long as it needs.
- **Control exports.** Decide who may export arrival lists and where they go. Prefer a shared secure folder or the PMS itself over email attachments.
- **Close old connections.** List every integration and API key once a quarter. Remove any you do not recognise or no longer use.
- **Update.** Install updates for locally installed software and operating systems. If the product is a cloud service, the vendor does this, but your own computers and browsers still need it.
- **Back up and test.** Keep a recent copy of your reservations and guest list somewhere the system itself cannot overwrite, and check once that you can actually read it.

When the system itself is the problem

Sometimes the risk is the supplier. Warning signs include no MFA option, no data-processing agreement, no answer about data location, passwords sent by email in plain text and a support team that asks for your login. If a vendor will not change, plan to move. In the meantime, reduce what the system holds and who can reach it.

A fictional example

Hotel Marina, a twenty-room property, used a channel manager that an old freelancer had set up. Four people used one login. A phishing email captured it. The attacker did not steal data. Instead, at two in the morning, they closed every room for the next fortnight on every platform. The hotel discovered it at breakfast when the phones stopped ringing. The cost was a fortnight's lost bookings and a long afternoon on the phone. The fix took forty minutes: named accounts, MFA, a new password and a review of connections. All of it was possible a year earlier.

CHAPTER 4

Guest-Data Access and Staff Permissions

CHAPTER 4
GUEST-DATA ACCESS AND STAFF PERMISSIONS

A corridor of numbered doors is a good model of room-by-room access

Most small-property data breaches are not exotic. They are an ordinary person with too much access, an account nobody removed, or a spreadsheet that went somewhere it should not. The cure is dull and effective: give people the access they need and no more, and take it away on time.

Least access in one sentence

Each person should see only the guest data their job needs, and only while they are doing that job. A housekeeper needs room numbers and cleaning notes; they do not need a guest's phone number or payment method. A night receptionist needs arrivals and room status; they do not need three years of stay history. An accountant needs invoices; not passport scans.

Four tiers that fit a small property

Four access tiers that work for a property of any size

Tier 1: owner or administrator. Full access, including users, payouts, exports and settings. As few people as possible; ideally two so the business is never locked out, each with their own account and MFA.

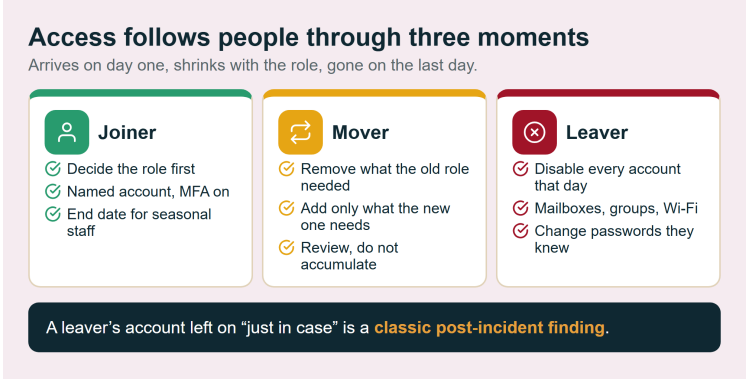
Tier 2: duty manager or reservations. Can see guest records, messages and payments for the current and upcoming stays, can modify bookings, but cannot change payout details, add users or export the whole database.

Tier 3: front-desk and night staff. Can see today's and tomorrow's arrivals and the details needed to check in a guest. Cannot see old stays, cannot export, cannot change bank or payout details.

Tier 4: housekeeping, maintenance and external helpers. Can see room status and tasks. Nothing about the guest beyond what the task needs (for instance, "do not disturb" or "late check-out").

Appendix B turns this into a matrix you can fill in. If your PMS has no roles, the next best thing is to restrict who has the login at all and to cut what you store.

The staff lifecycle: joiners, movers, leavers



Access should follow people through the three moments that matter

Joiners. Before day one, decide the role. Create a named account at that tier, switch on MFA with the person present and record what was granted. Seasonal and agency staff get the same treatment, with an end date set at the start.

Movers. When someone changes job, review access: remove what the old role needed and add only what the new one does. Accumulated access is a quiet risk.

Leavers. On the last day, ideally the last hour, disable every account, remove them from shared mailboxes, remove their devices and change any password they knew. This includes platform extranets, the PMS, email, messaging groups, the Wi-Fi password and any payment tools. A leaver's account staying active for "a few weeks, just in case" is one of the most common findings after an incident.

Keep a simple record: name, role, accounts, start date, end date, who removed access and when. Appendix B has a page for it.

> **The rule:** Access should arrive on the first day, shrink when the role changes and be gone on the last.

Passwords, phones and personal devices

Small properties often work from personal phones. That is practical, and it carries risk.

- **Lock the device** with a PIN or biometric and automatic lock.
- **Keep work apps separate** where the phone allows (work profile or separate user).

- **Do not forward guest data to personal email or chat** to "save time".
- **Report a lost phone at once,** so sessions can be revoked and passwords changed.
- **Never save passwords in a notes app or on paper at the desk.** Use a password manager, or at minimum keep a paper record in a locked drawer, not under the keyboard.

Shared mailboxes and messaging groups

A shared mailbox such as reservations@ is convenient and risky. Everyone who can open it can read every guest message, and can often reset passwords for other systems from it. Limit who has access, use individual sign-ins to the shared inbox where possible and turn MFA on. Treat a team messaging group the same way: it is a record of guest data, not a chat, and its members should be reviewed like a user list.

Sharing guest data outside the property

Guests' data goes to cleaners, laundry, tour partners, transfer drivers, accountants and tax advisers. Each is a recipient. The rules are simple to state.

- Share **only what the task needs.** A driver needs a name, a time and a pickup address, not a phone number list.
- Use a **secure channel,** not an open messaging group.
- Where an outside company handles guest data **on your behalf** (for example a laundry that sees names), put a written agreement in place and keep it.[5]
- Delete the data **after the job.** A transfer list from last July should not still be in a driver's inbox.

Monitoring and logs

You cannot protect what you cannot see. Where the PMS offers an activity log, switch it on and look at it monthly: who exported what, who looked up whom, and from where. If you monitor staff, tell them first and keep it proportionate; secret surveillance can itself breach the privacy of employees.

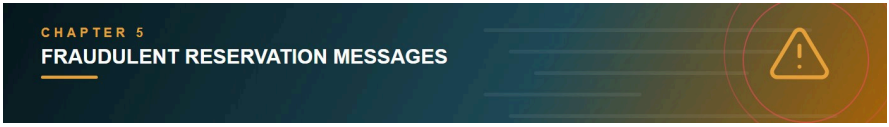
A quick audit you can do in an hour

1. List every user of the booking platforms, channel manager, PMS and shared mailboxes.
2. Beside each name, write their role and whether they still work for you.

3. Remove or disable anyone who has left or never used the account.
4. Check that each remaining person has the lowest role that works.
5. Check that MFA is on for each.
6. Write the date at the bottom and put a reminder in the calendar for three months from now.

CHAPTER 5

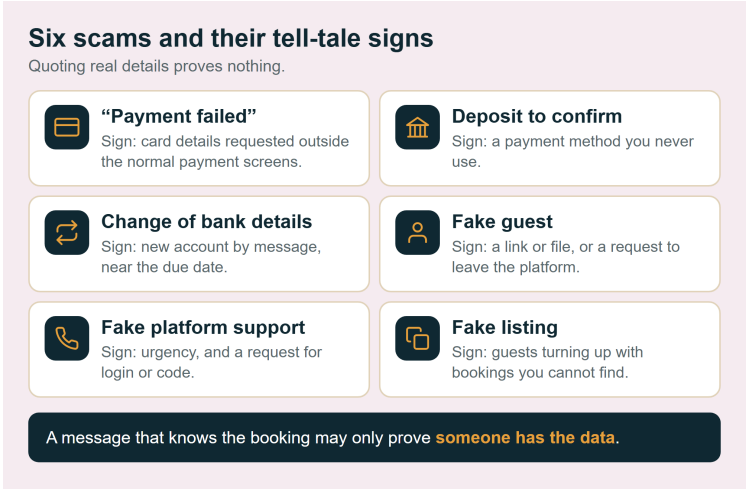
Fraudulent Reservation Messages



A phone lighting up on the counter: the scam arrives where the guest is already looking

The Villa Lavanda scam in the introduction is the pattern to learn. It works because it uses real information. A generic "your booking is cancelled" message is easy to ignore. A message that gives your name, your dates, your room type and the exact price is hard to doubt. The criminal does not need to break into the guest's life. They only need a copy of the reservation.

Six scams you will meet



Six common fraudulent reservation messages and the tell-tale sign of each

1. The "payment failed" message. The guest is told the card on the booking has been declined, and that the booking will be cancelled unless they "re-enter" their details by a link or through a messaging app. The sign: it asks for card details outside the platform's normal payment screens and demands speed.

2. The "confirm your booking" deposit. The guest is asked to pay a deposit or "verification fee" to a bank account or payment link. The sign: a payment method you never use, usually a transfer or a link to an unfamiliar page.

3. The change-of-bank-details request. A message claiming to be from you tells a group or corporate guest the account has changed for the balance. The sign: new bank details arriving by message, close to the due date.

4. The fake guest. A "guest" contacts you with a booking enquiry and then sends a link to "see the dates", a "payment confirmation" attachment, or a request to move the chat to another app. The link or file steals your login or installs malware. The sign: the request to leave the platform.

5. The fake platform support. A message or call says a guest has complained, a payout is blocked or your listing is suspended, and asks you to click or call. The sign: urgency and a request for a login or a code.

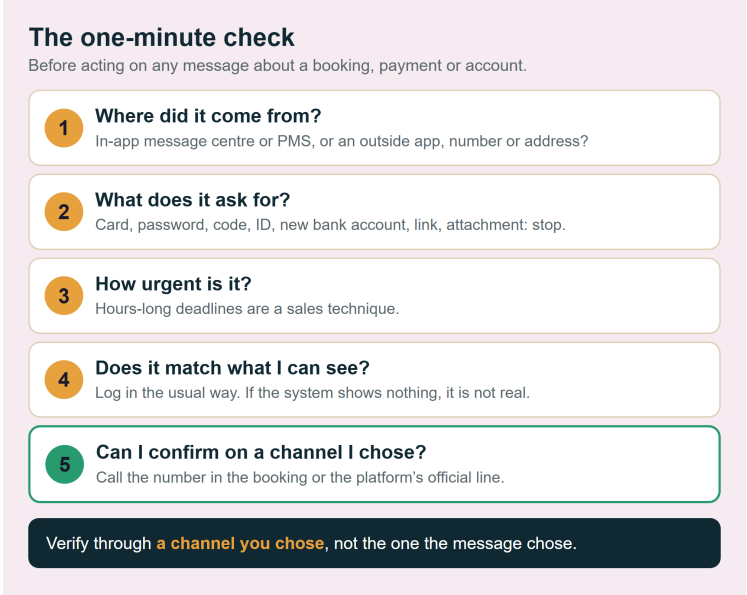
6. The fake listing. Your photos and description are copied onto a listing elsewhere, taking deposits from guests for a room you do not know exists. The sign: guests arriving or calling about bookings you cannot find. This is the kind of risk that regulators are examining on large platforms.[1]

How the criminals get the details

The honest answer is that a guesthouse usually cannot know. The route can be a compromised platform or PMS account, a malware-infected computer, a leaked spreadsheet, a message the guest forwarded, or a data leak elsewhere. Reports of this wave describe criminals who appear to hold real reservation details and who may have obtained them by phishing hotel accounts.[2][3] What matters is that **a message that quotes real details is not proof that it is real**. It may only be proof that someone has the data.

The one-minute check

When a message about a booking, a payment or a change arrives, whether you are the recipient or a guest has forwarded it to you, run this check before doing anything else.



Five questions to ask before you act on any message about a reservation

1. **Where did it come from?** The platform's in-app message centre, your PMS, or an outside app, number or address? Platforms generally want conversations kept on the platform.
2. **What does it ask for?** Card numbers, passwords, codes, identity scans, a new bank account, a payment link or an attachment: stop.
3. **How urgent is it?** A deadline of "two hours" or "today or we cancel" is a sales technique, not an administrative need.
4. **Does it match what you can see?** Log in the usual way, not through the message, and look. Is there a payment problem? A complaint? A change request? If the system shows nothing, the message is not real.
5. **Can you confirm on a second channel?** Call the guest on the number in your booking record, or the platform on its official support number. Never use a number or link supplied in the message.

If any answer worries you, do not click, do not pay, do not forward the link, and tell a colleague. Then report it (below).

> **The rule:** If a message creates urgency and asks for money or secrets, verify through a channel you chose, not the one it chose.

What to do when a guest has been targeted

A guest like Mr Albrecht will ring you, upset. How you respond matters both to him and to your legal position.

1. **Listen and reassure.** Do not blame him. He was deceived by a skilled message.
2. **Advise him to contact his bank at once.** Stopping a card quickly is the most useful thing he can do.
3. **Do not confirm or deny details over an unverified channel.** Take his number and call back on the one in his booking.
4. **Collect the evidence.** Ask for screenshots of the message, the sender's number or address, and the link. Do not click it yourself.
5. **Record the incident** in your log (Appendix E), with times.
6. **Check your own systems.** The fact that the message knew details means they came from somewhere. Treat it as a possible breach and read Chapter 7.
7. **Report it.** Tell the platform if the reservation came through it, and consider reporting to the police or your national fraud-reporting service.

Reporting and warning others

Report fraud to the platform's official channel, found on its help pages. Tell your team and, if your business belongs to a hospitality association, tell them too; their warnings often come from members' reports. Put a **short, plain notice on your own website and in your confirmation emails** saying how you will and will not contact guests (Chapter 6). A guest who knows your rules can spot an impostor without calling anyone.

What not to do

- Do not reply to the scammer or click the link to "investigate".
- Do not delete the evidence.
- Do not announce on social media that a particular guest was deceived.
- Do not assume the leak came from your own staff without evidence.
- Do not wait for certainty before logging the incident. You can log it now and refine it later.

CHAPTER 6

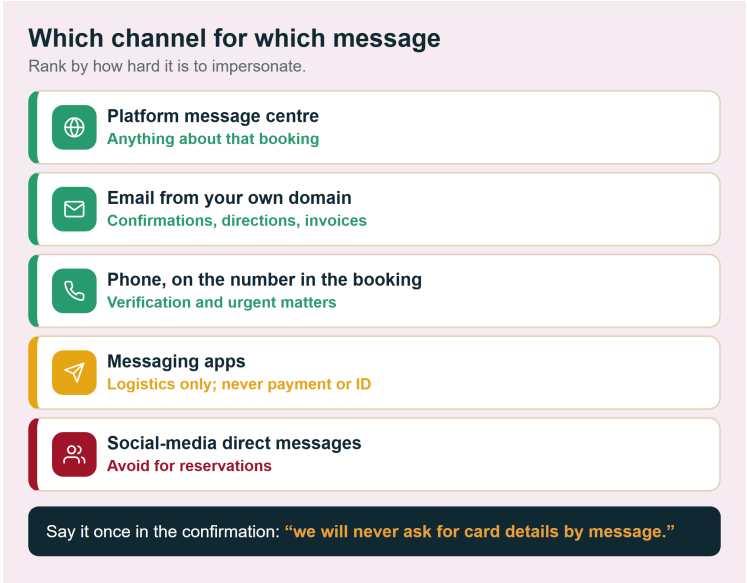
Secure Guest-Communication Procedures

A quiet breakfast room: guests should know exactly how you will contact them

The best defence against an impostor is a guest who already knows how the real you behaves. If you tell guests in advance what you will never ask for and where you will contact them, a fake message stands out immediately. This is the cheapest, most effective control in the book, and it costs almost nothing.

Decide your channels

Most properties communicate through five channels. Rank each by how safe it is for sensitive matters.



Which channel for which kind of message

Platform message centre. For anything about a booking made on that platform. It keeps a record, is attached to the reservation and is harder to impersonate than a phone number. Keep conversations here wherever possible.

Email from your business domain. Suitable for confirmations, directions and invoices. Use a domain you control, not a free personal address. Switch on MFA for the mailbox and consider a policy that stops others sending as your domain, which your IT helper can set up.

Phone call. Best for verification and urgent matters, because a voice you or the guest recognise is harder to fake than text. Use a number the guest can find in their booking, not one that appears only in a message.

Messaging apps. Convenient for practical contact such as "I'm at the gate". They are the favourite channel of impostors because numbers and names are easy to copy. Use them for logistics only, never for payments or identity documents.

Social media direct messages. Avoid for anything involving a reservation.

The "we will never" list

Publish a short, fixed statement in your confirmation email, on your website and at check-in. Choose the wording that fits your property, and keep it the same everywhere.

We will never ask you to:

- send full card details by email, message or chat;
- pay a deposit or balance to a new bank account announced by message;
- click a link to "confirm" or "re-confirm" your booking;
- share a password or a one-time code;
- send a photo of your passport or ID through a messaging app.

We will always:

- contact you through the booking platform or from our official email address;
- give you our telephone number so that you can call us to check;
- tell you at check-in how we will handle any payment.

Put the same lines in your auto-reply, on a card at the desk and in the welcome message. Repeating it is the point.

Handling payment

Payment is where fraud turns into loss, so decide in advance and keep it dull.

- **Prefer the platform's own payment route** where it exists, so guests never type card details into your messages.
- If you take your own payments, use a **reputable payment provider's hosted page** or a card terminal; never ask for card numbers by email or chat.
- Say clearly, in the booking confirmation, **how and when** any deposit or balance will be paid.
- **Do not change bank details by message.** If you must, confirm by phone with the guest on the number in the booking.
- Treat any request for a payment from a staff member's personal account as a red flag, even when well meant.

Identity documents and special requests

Some countries require guest registration or identity checks, and the rules differ. Find out exactly what your law requires, then do only that.

- Ask for documents **at check-in, in person,** wherever possible, not by message.
- If you must collect scans in advance, use a **secure upload** that the PMS or a trusted provider offers, and delete them when the legal need ends.

- Never ask guests to send identity documents by messaging app or ordinary email.
- Keep **health, religion and accessibility details** to the minimum needed, and record them as a task ("step-free room"), not as a diagnosis.[4]

Scripts for the front desk

Staff are more likely to behave well when they have the words. Short scripts work better than policies; Appendix D gives you a full set. Three examples:

A guest says they got a message asking for card details. "Thank you for telling us. That did not come from us, and we will never ask for card details by message. Please contact your bank now and don't click the link. Can you forward me a screenshot, and may I call you back on the number in your booking?"

Someone phones claiming to be a guest and asks you to change the booking, move the payment or send a copy of the reservation. "I'm happy to help. For security, I will call you back on the number in the booking. May I do that now?"

Someone phones claiming to be the platform. "Thanks. I will call the platform back on the number on its help page." Then do exactly that.

Check-in and check-out security

Fraud and data loss also happen in person.

- **Screens face away from the desk.** A guest at the counter should not see another guest's booking.
- **Say a name quietly,** or write it down, rather than announcing room numbers and surnames.
- **Printed arrival lists** are locked away at night and shredded when finished.
- **Key cards** are encoded with a room and date, not with a guest's name.
- **Post-stay messages** such as review requests go through the platform, not from a personal account.

Responding to a guest's data request

Guests may ask what you hold about them or ask you to delete it. Treat it as routine: confirm their identity through the contact details in the booking, check what you hold in the PMS, platform and email, and respond within

the legal deadline, which is generally one month.[7] Do not send a guest's data to an address supplied in a message; send it to the contact in the booking.

> **The rule:** Tell guests in advance how you will and will not contact them, and an impostor has to work much harder.

CHAPTER 7

GDPR Breach Escalation

A locked office safe is no use if nobody knows who has the key to the incident plan

Sooner or later something will go wrong: a phished account, a scam that quotes a real booking, a laptop left on a train, a spreadsheet sent to the wrong person. The law does not expect you to prevent every incident. It does expect you to **notice, assess, record and, where required, report**, quickly. A small property that has decided in advance who does what will handle a bad night far better than one that is working it out as the phone rings.

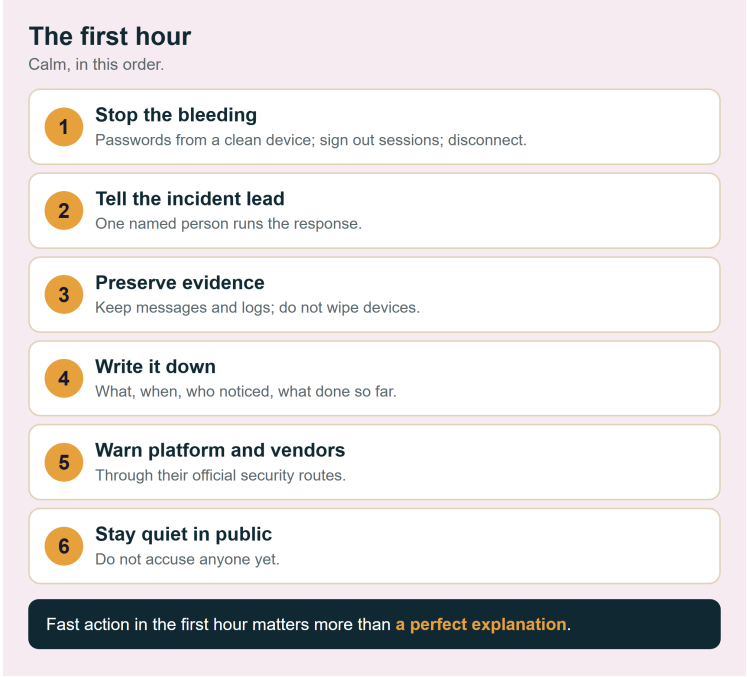
What counts as a personal-data breach

Under the GDPR, a personal-data breach is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data.[6] It is wider than hacking. In a guesthouse it includes:

- an attacker logging into a booking or PMS account;
- a scam message that quotes real reservations, if the data came from your systems;
- a lost or stolen phone, laptop or paper arrival list;
- an email or message with guest data sent to the wrong person;
- a former employee who still has access and uses it;
- a vendor telling you that its systems were breached;
- ransomware that locks or copies your guest records.

A breach is about **data**, not about whether anyone was harmed yet. And "we are not sure" is the usual starting point.

The first hour

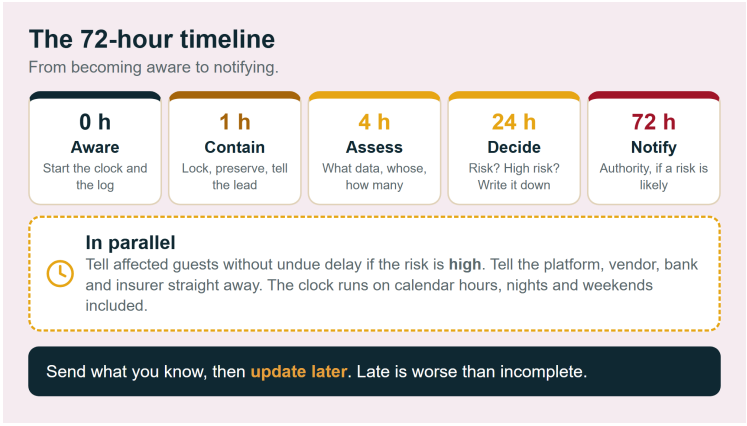


Six steps to take in the first hour after you suspect an incident

1. **Stop the bleeding.** Change passwords from a clean device, sign out all sessions, disconnect an infected computer from the network, and ask the platform or vendor to lock the account.
2. **Tell your incident lead.** One named person (Appendix E) runs the response, so everyone does not run in different directions.
3. **Preserve evidence.** Keep messages, screenshots, logs and emails. Do not wipe devices or delete the suspicious message.
4. **Write it down.** Start the log: what you saw, when, who noticed, what you have done so far.
5. **Warn the platform and your vendors** through their official security routes.
6. **Do not communicate publicly,** and do not accuse anyone, until you know more.

The 72-hour clock

When a personal-data breach occurs, the controller, which for your guests' data is generally you, must notify the supervisory authority **without undue delay and, where feasible, not later than 72 hours after having become aware of it**, unless the breach is unlikely to result in a risk to people's rights and freedoms.[6] A few points matter a great deal in practice.



The breach timeline: from awareness to notification, with the decisions on the way

- **The clock runs on calendar hours,** including nights, weekends and public holidays.
- **It starts when you become aware,** meaning you have a reasonable degree of certainty that a breach affecting personal data has happened. It does not wait for the full investigation. You can send the information in phases.
- **Your processors must tell you without undue delay** when they become aware of a breach affecting your data.[6] When a vendor tells you, your own clock is likely to start then, so make sure the vendor knows who to contact and how.
- **You must document every breach,** including those you decide not to report: the facts, the effects and what you did.[6]

Deciding whether to report

Ask three questions, quickly, and write the answers in the log.

Is it a breach? Is there a risk? Is the risk high?

1. Did personal data suffer a security incident? If the answer is no, it is a security matter, not a data-protection one. If yes or unsure, continue.

2. Is it unlikely to result in a risk to the people concerned? Consider what was exposed (names only, or card details, identity documents, health notes), how many guests, whether the data could be misused, and whether it was protected by encryption. If a risk is unlikely, you record the breach but need not notify the authority. Be honest: a guest list with phone numbers and booking details used for scams carries a real risk.

3. Is the risk high? If so, you must also **tell the affected guests without undue delay**, in clear language, saying what happened, what data was involved, what you are doing and what they can do to protect themselves. [6] Payment-card data, identity documents, health details and details used to impersonate you are the usual examples.

When you are unsure, the cautious path is to notify. A well-prepared report that turns out to be unnecessary is far better than a late one.

> **The rule:** Decide who runs an incident, and what they will do in the first hour, before the incident happens.

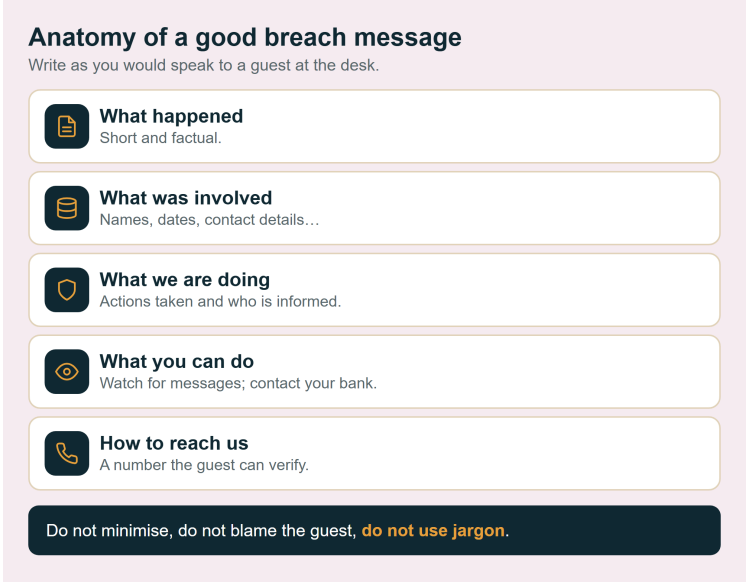
Who you may need to tell

Who	When	Why
Your data-protection authority	Within 72 hours, if the breach is likely to result in a risk	Legal duty
Affected guests	Without undue delay, if the risk is high	Legal duty and protection
The booking platform	At once, if its account or data is involved	Lock accounts, investigate, warn others
Your vendor (PMS, channel manager)	At once if its system is involved	Logs, containment, its own obligations
Your bank or payment provider	At once if payments or payouts are affected	Stop fraudulent charges or diversion
Your insurer	As the policy requires, often promptly	Cover can depend on prompt notice
The police or fraud agency	For fraud, theft or extortion	Evidence and reference number
Staff	As needed	They must know what to say and not say

What to tell the authority

Most authorities have an online form. You will generally be asked what happened, when you became aware, the categories and approximate number of people and records, the likely consequences, what you have done and a contact point.[6] If you do not yet know everything, say so and send an update later.

What to tell your guests



A good breach message is short, specific and calm

Write as you would to a guest at the desk. Say what happened, what information was involved, what you are doing, what you advise them to do (for example, watch for suspicious messages and contact their bank), and how to reach you on a number they can verify. Do not minimise, and do not blame the guest. Appendix D has a template.

After the incident

Once the crisis eases, hold a short review. What was the root cause? Which control would have prevented or caught it? Update your checklists, tell staff what changed and note the date in your log. Treat near misses the same way; a phishing email caught in time is a free lesson.

Preparing before the bad night

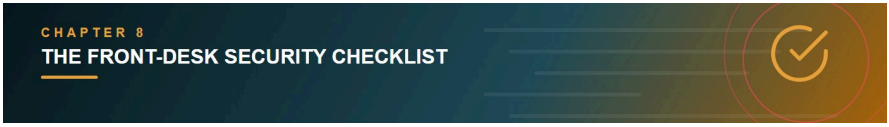
Ten minutes now saves hours later.

- ☐ Name an incident lead and a deputy, with their mobile numbers.
- ☐ Put the regulator's online reporting address and the platform security routes in the appendix.
- ☐ Keep an up-to-date list of systems and vendors (Appendix A).
- ☐ Know where backups are and how to restore.

- ☐ Check whether your insurance includes cyber cover, and what it requires.
- ☐ Practise once: read a fictional scenario aloud and walk through the steps.

CHAPTER 8

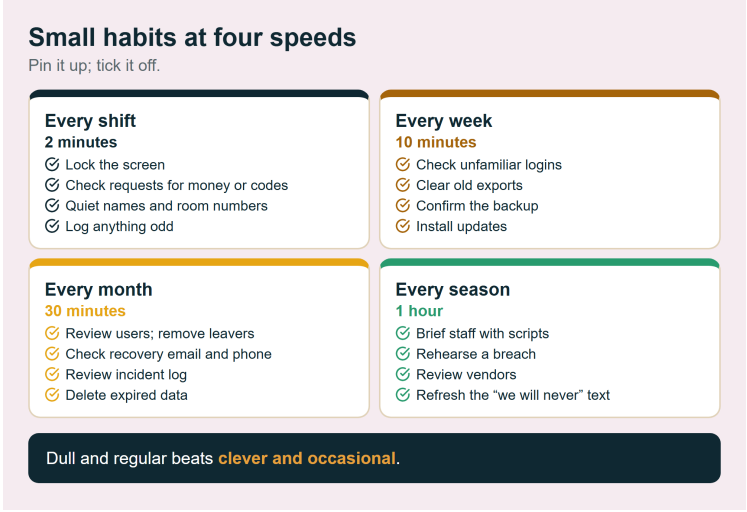
The Front-Desk Security Checklist



A calm harbour town: security that is steady and boring is the goal

A policy no one reads protects no one. The most effective security in a small property is a short list that sits on the desk and is used every day. This chapter turns the previous seven into one.

The rhythm: daily, weekly, monthly



Small habits at three speeds

Every shift (two minutes)

- ☐ Lock the screen whenever you step away from the desk.
- ☐ Check that no unfamiliar person, device or "support" visit is waiting.
- ☐ Read new messages in the platform message centre, and do not act on any request for money, codes or card details until it has passed the one-minute check.
- ☐ Do not read out a guest's full name and room number where others can hear.
- ☐ Put printed arrival lists in the locked drawer; shred yesterday's.
- ☐ Note anything odd in the incident log, however small.

Every week (ten minutes)

- ☐ Check the platform and PMS for logins from places or devices you do not recognise.
- ☐ Confirm that no new users, apps or connections have appeared.
- ☐ Clear downloaded arrival-list exports from computers and shared folders.
- ☐ Test one backup or confirm the last one completed.
- ☐ Check for software and phone updates.
- ☐ Read the week's suspicious messages and share the pattern with the team.

Every month (thirty minutes)

- ☐ Review every user of every system; remove leavers and unused accounts.
- ☐ Review roles against Appendix B; reduce any access that has crept up.
- ☐ Check recovery email and phone numbers on each platform.
- ☐ Review the incident log and update the checklist.
- ☐ Check vendor notices and any change in their security terms.
- ☐ Delete guest data you no longer need under your retention rule.

Every season (one hour)

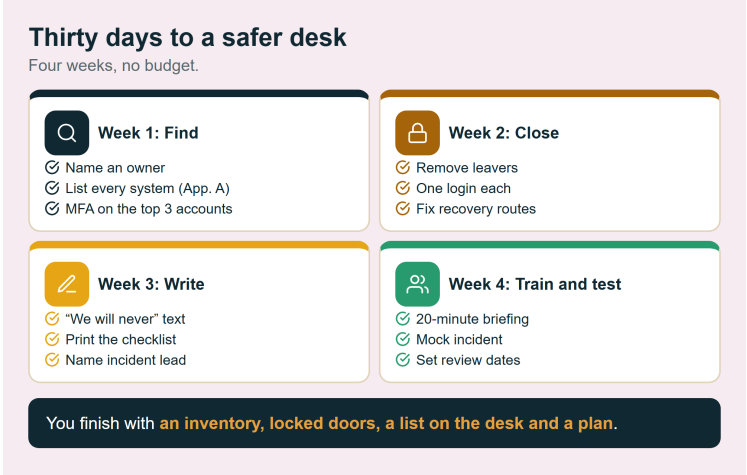
- ☐ Brief new and returning staff with the "we will never" list and the scripts.
- ☐ Rehearse a breach scenario with the incident lead.
- ☐ Review all vendors against the ten questions in Chapter 3.
- ☐ Review your privacy notice and "we will never" statement.

Retention: how long to keep what

Holding guest data for longer than you need is a risk and a legal problem, because the GDPR requires that personal data be kept only as long as necessary for the purpose.[8] Decide a period for each type and write it down. The right periods depend on your country's tax, accounting and registration rules, so check them. The pattern is usually:

Data	Typical approach
Messages and enquiry notes	Delete a short time after departure
Arrival and registration data	Keep for the period the law requires, then delete
Invoices and accounting records	Keep as tax and accounting law requires
Passport or ID scans	Keep only if the law requires it, and delete as soon as it allows
Marketing contacts	Keep while consent or the lawful basis lasts; delete when withdrawn
Health and accessibility notes	Convert to a task; delete after the stay

Thirty days to a safer desk



A thirty-day plan in four weeks

Week 1: find. Name an owner. List every system, shared mailbox and person with access (Appendix A). Turn on MFA for the two or three accounts that matter most, usually the main platform, the channel manager and the email.

Week 2: close. Remove unused accounts and leavers. Give everyone their own login. Fix recovery emails and phones. Change default and shared passwords. Check vendor answers to the ten questions.

Week 3: write. Publish the "we will never" statement. Print the one-minute check and the front-desk checklist. Agree the incident lead and write down the 72-hour steps. Set retention periods.

Week 4: train and test. Run a twenty-minute briefing with scripts. Run a mock incident. Review the first three weeks and set the monthly review dates.

You will finish with an inventory, a set of locked doors, a short list on the desk and a plan for the bad night. None of it needs a budget. All of it needs a decision to start.

What good looks like

Imagine the same Friday night, in a property that has done this work. The message arrives at Mr Albrecht's phone. But his booking confirmation told him the property will never ask for card details by message. He rings the number on his confirmation. Pavle thanks him, tells him to ignore it, and opens the incident log. Within the hour the extranet shows a login from an unknown country, which Pavle blocks with a password change and a call to the platform. By Saturday noon the team knows what happened, what data was exposed and what to tell guests. The authority is told on Sunday, well inside 72 hours. Nobody loses money.

Nothing in that story required a security expert. It needed a promise made in advance and a few habits kept.

Conclusion: Guard the Desk, Keep the Welcome

A lit guesthouse at blue hour: the aim is hospitality, not fortress

Hospitality is built on trust. Guests give you their names, their dates, their money and sometimes their health details because they expect a warm welcome and a safe stay. The booking desk is where that trust is exchanged, and these days the desk is not just a counter. It is a platform login, a channel manager, a PMS and a phone in your pocket.

That is the whole shape of the approach. **Know the chain. Close the easy doors. Give people only the access their job needs and take it away on time. Say in advance how you will and will not contact guests. Check before you believe a message that asks for money or secrets. Know who runs the first hour of an incident, and keep the 72 hours in your head.**

None of this makes a property a fortress, and it should not. A hotel that is hard to enter and cold to arrive in has missed the point. The aim is a place where a guest can relax because the unglamorous work behind the desk has been done.

Laws will tighten, platforms will change their controls, regulators will conclude their investigations and criminals will find new stories. Your inventory, your checklist and your habits are what let you adapt without panic.

Start with the ten-minute check. Fill in Appendix A this week. Turn on multi-factor authentication on the one account that matters most tonight. Then pin up the checklist and let your guests know how you will look after

them.

APPENDIX A

Booking-Desk System Inventory

Complete one row for every system, account or mailbox that holds or can reach guest data, including free tools, spreadsheets and personal phones used for work. Ask staff without blame. Review every quarter.

System (platform, channel manager, PMS, payment, email, messaging)	Who has access	Owner	MFA on?	Reset email / phone	Holds (names, ID, cards, health)	Data location	Agreement signed?

Account hygiene check (record date and who checked):

- ☐ Every platform, channel-manager and PMS login uses multi-factor authentication.
- ☐ No shared logins; each person has a named account.
- ☐ Reset emails and phones belong to the business and are controlled by a named person.
- ☐ Default and installer accounts have been renamed, disabled or given new passwords.
- ☐ All connected apps, integrations and API keys have been listed and are still needed.
- ☐ Payout and bank details can be changed only by the owner or finance lead.
- ☐ Exports of guest lists are limited to named people and stored securely.
- ☐ Backups exist, are separate from the live system and have been tested.

Checked by: _____ Date: _____

APPENDIX B

Role-and-Permission Matrix and Staff Access Register

Tick what each tier may do. Adapt to your property. Have the owner approve it, and review it every quarter.

Access	Tier 1 Owner/admin	Tier 2 Manager/reservations	Tier 3 Front desk/night	Tier 4 Housekeeping/maintenance
See current and upcoming guest details	✓	✓	✓	Room tasks only
See past stays and history	✓	✓		
See contact details (phone, email)	✓	✓	✓	
See payment details or virtual card	✓	✓	Limited	
See ID, passport or health notes	✓	Only if required	Only at check-in	
Change bookings and prices	✓	✓		
Export guest lists	✓	Named only		
Add or remove users	✓			
Change payout or bank details	✓			
Connect or remove apps and integrations	✓			

Access	Tier 1 Owner/admin	Tier 2 Manager/reservations	Tier 3 Front desk/night	Tier 4 Housekeeping/maintenance
Your own:				

Staff access register

Name	Role / tier	Systems and accounts	Start date	End date	Access removed by (name, date)

Leaver checklist:

- ☐ Platform extranets and channel manager disabled.
- ☐ PMS, email and shared mailboxes removed.
- ☐ Messaging groups and Wi-Fi password changed.
- ☐ Payment tools and keys collected or revoked.
- ☐ Any password the person knew has been changed.
- ☐ Devices returned and work data removed from personal phones.

APPENDIX C

Suspicious-Message Triage Card

Print this on one page and keep it at the desk. Use it for any message, call or email about a booking, payment, account or "urgent" problem.

#	Question	Answer	Action if the answer worries you
1	Where did it come from? Platform message centre, PMS, or an outside app, address or number?		Treat outside channels as unverified
2	What does it ask for? Card details, password, code, ID scan, new bank account, link or attachment?		Do not give, click or pay
3	How urgent is it? Any deadline measured in hours?		Slow down; urgency is the trick
4	Does it match what I can see when I log in the usual way?		If the system shows nothing, it is not real
5	Can I confirm on a second channel I chose (the number in the booking, the platform's official support)?		Call back; never use contact details from the message

If still unsure: do not click, do not pay, do not forward the link. Tell the duty manager. Take a screenshot. Record it in Appendix E.

Never type or read out: passwords, one-time codes, full card numbers.

Report to: platform security (official help page): _____ Duty manager: _____ Incident lead: _____

APPENDIX D

Guest-Communication Scripts and Templates

Adapt the wording to your tone and language. Keep it identical wherever it appears.

1. The "we will never" statement (confirmation email, website, welcome card)

> We will never ask you to send full card details by email or message, to pay a deposit to a new bank account announced by message, to click a link to "confirm" your booking, or to share a password or code. If you receive a message like this, please do not respond. Contact us on _____ (the number on your booking) and we will check.

2. A guest says they received a suspicious message

> Thank you for telling us. That did not come from us. Please do not click anything or reply, and contact your bank now if you shared any card details. Could you send us a screenshot, and may I call you back on the number in your booking?

3. A caller asks to change a booking, payment or details

> I am happy to help. For your security I will call you back on the number in your booking. May I do that now?

4. A caller says they are from the booking platform

> Thank you. I will call the platform back on the number on its official help page.

5. A guest asks what data you hold

> Thank you for your request. To protect your privacy I will confirm your identity using the contact details in your booking, and reply within one month.

6. Breach notice to guests (draft; adapt facts; take advice for high-risk cases)

> Subject: Important information about your booking with [Property]
>
> We are writing to tell you about a security incident that may affect information about your booking. On [date] we discovered that [short, factual description]. The information involved may include [names, contact details, dates of stay, other]. We have [actions taken] and have informed [authority/platform].
>
> What you can do: please be cautious of messages that quote your booking and ask for payment or details. We will never ask for card details by message. If you shared card details, contact your bank immediately.
>
> You can reach us on [verified number] or at [verified email]. We are sorry for the worry this causes, and we will update you if we learn more.

APPENDIX E

Incident Contacts, 72-Hour Steps and Incident Log

Contacts (fill in now, not during the incident)

Role	Name	Mobile	Backup
Incident lead			
Deputy			
Owner / decision-maker			
IT helper or vendor support			
Insurer (policy no.)			
Data-protection authority online form			
Platform security routes			
Bank / payment provider fraud line			

The 72-hour steps

- ☐ **Hour 0-1:** contain (passwords from a clean device, sign out sessions, disconnect), tell the incident lead, preserve evidence, start the log.
- ☐ **Hour 1-4:** notify the platform and vendors; notify bank or payment provider if money is involved.
- ☐ **Hour 4-24:** establish what data, whose and how many; decide whether a risk is likely; decide whether it is high.
- ☐ **By hour 72 (calendar hours):** notify the authority if required, even if details are incomplete; send updates later.
- ☐ **Without undue delay:** tell affected guests if the risk is high.
- ☐ **After:** review, update checklists and record the decision, including a decision not to notify.

Incident log

Date and time noticed	Who noticed	What happened	Systems and data involved	Number of guests	Actions and time	Risk assessment and decision	Notified (who, when)

APPENDIX F

The Front-Desk Security Checklist (Print and Pin)

Every shift

- ☐ Screen locked when I leave the desk.
- ☐ No arrival lists or guest details visible to other guests.
- ☐ Every request for money, codes, card details or new bank details checked (Appendix C).
- ☐ Anything odd written in the log.

Every week

- ☐ Unfamiliar logins, users or connections checked.
- ☐ Old exports and downloaded lists deleted.
- ☐ Backup confirmed.
- ☐ Updates installed.

Every month

- ☐ User lists reviewed on every system; leavers removed.
- ☐ Roles reviewed against Appendix B.
- ☐ Recovery emails and phones checked.
- ☐ Incident log reviewed.
- ☐ Guest data past its retention period deleted.

Every season

- ☐ Staff briefed; scripts practised.
- ☐ Breach scenario rehearsed.
- ☐ Vendors reviewed against the ten questions.

Reviewed by: _____ Date: _____

APPENDIX G

Retention Register and 30-Day Tracker

Retention register

Data type	Where it is held	Purpose	Keep for	Delete or anonymise how	Owner
Messages and enquiry notes					
Arrival and registration data					
Invoices and accounts					
ID or passport scans					
Marketing contacts					
Health and accessibility notes					

30-day tracker

Week	Task	Owner	Due	Done
1	Name an owner; complete Appendix A			☐
1	MFA on main platform, channel manager and email			☐
2	Remove leavers; one login per person			☐
2	Fix recovery emails and phones; change default passwords			☐
2	Send the ten vendor questions			☐
3	Publish the "we will never" statement			☐
3	Print Appendices C and F; pin at the desk			☐
3	Name incident lead; fill in Appendix E contacts			☐
3	Set retention periods (Appendix G)			☐

Week	Task	Owner	Due	Done
4	Brief staff with scripts (Appendix D)			☐
4	Run a mock incident			☐
4	Set monthly and seasonal review dates			☐

Glossary

Booking platform. An online marketplace where guests find and book accommodation; the host manages bookings in an account often called an extranet.

Channel manager. Software that keeps rates and availability the same across several booking platforms.

Controller. The organisation that decides why and how personal data is used. For your guests' data, usually you.

Data-processing agreement. A written contract with a supplier that handles personal data on your behalf, required by GDPR Article 28.

Extranet. The control panel through which a host manages a listing on a booking platform.

MFA (multi-factor authentication). Signing in with something more than a password, such as an app code or a security key.

Passkey. A phishing-resistant sign-in method that replaces a password with a cryptographic key stored on a device.

Personal-data breach. A security incident that causes accidental or unlawful destruction, loss, alteration, unauthorised disclosure of or access to personal data.

Phishing. A message designed to trick someone into giving away a password, code or payment details.

PMS (property-management system). The software that holds guest records, room status and invoices.

Processor. A supplier that handles personal data on a controller's behalf.

Supervisory authority. The national or regional body that enforces data-protection law and receives breach notifications.

Sub-processor. A supplier used by your supplier to help process your data.

A Note on GDPRGard.eu

If your booking-desk work touches personal data, the free tools, guides and articles at **gdprgard.eu** can help with the surrounding tasks: records of processing, impact assessments, breach response and privacy notices. They are a companion resource, not a substitute for advice on your own situation.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, cyber-security, AI and building a business with confidence. She believes technology should give small businesses and the people in them more control, not less, and that nobody should need a law degree or a technical background to understand their rights or protect their customers and colleagues.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex rules and fast-moving technology into simple steps, checklists and templates that busy people can use on Monday morning. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

The Booking Desk Is a Security Boundary grew out of a simple observation: small properties hold more guest data than they realise, in more places than they can name, and the first people to be targeted are the ones with no security team. If this guide helped you, an honest review where you bought it helps other readers find it.

Visit **gdprgard.eu** for free tools, articles and updates.

Notes and Sources

1. European Commission, opening of formal proceedings under the Digital Services Act against Booking.com, 21 October 2026, concerning the assessment and mitigation of risks from fraudulent listings and phishing, and the labelling of paid rankings as advertising. Seen through press and legal-news summaries (including the Commission-related notices reproduced by LexisNexis, Courthouse News and a Spanish consumer-ministry portal); the Commission's own press release was not read. The Commission stated that opening proceedings does not prejudge the outcome. The platform was designated a very large online platform in April 2023, and the Commission had sent a request for information on scam risks in September 2025 (same summaries).
2. German hospitality association DEHOGA (Nordrhein regional body), warning of 2 November 2026 about booking-related scams using genuine reservation details and the possibility of compromised hotel accounts, PMS and channel managers, as described in the commissioning brief and the association's website. A further search for the warning text did not find the original notice, and found no source naming a specific PMS or channel-manager vendor as the origin of any attack. Read the original on dehoga.de before relying on it.
3. Press and fact-checking reports of the same scam wave (including Mimikama and c't magazine, as quoted by Techbook and Touristik Aktuell), describing attackers phishing hotel and holiday-let operators' booking accounts to obtain real reservation data. Seen only through search summaries; some regional hotel associations, including DEHOGA Berlin, are reported to point to weaknesses in reservation services.
4. Regulation (EU) 2016/679 (GDPR), Article 9 (special categories of personal data, including data concerning health). Working knowledge; read the text.
5. GDPR Article 28 (processor contracts) and Article 32 (security of processing). Working knowledge; read the text.
6. GDPR Articles 4(12) (definition of personal-data breach), 33 (notification to the supervisory authority within 72 hours, processor duty, content of the notification and duty to document breaches) and 34 (communication to data subjects where the risk is high). Working knowledge; read the text and your national authority's online guidance and form.
7. GDPR Articles 12 and 15 (data-subject access; one month to respond, extendable in some cases). Working knowledge; read the text.
8. GDPR Article 5(1)(c) and (e) (data minimisation and storage limitation). Working knowledge; read the text.
9. Advice that guests should never enter card details through email, chat or messaging apps, and that hotels should verify payment requests by phone using the number in the booking confirmation, as reported in Mimikama and tageskarte.io articles (seen through search summaries). Platform guidance changes; check the platform's own current help pages.

10. DEHOGA Baden-Württemberg warning on manipulated digital receipts and the advice to use dedicated mailboxes and not open attachments from unknown senders, as reported by tageskarte.io (seen through a search summary).

What could not be verified. No primary-source documents were read for this edition: not the Commission's press release or decision, not the DEHOGA notice, and not any platform's security documentation. The scenarios in this book are fictional. Check the vendor documentation, your regulator's guidance and, where needed, a lawyer before acting.